

# AWS 클라우드 보안 설정 및 점검 체크리스트

*AWS Cloud Security Configuration & Checklist*

**SGA솔루션즈 TTS사업본부 지원 포트폴리오**

컴퓨터정보학부 | 작성자: 이형석

2026년 6월

## 1. 프로젝트 개요

| 항목     | 내용                                    |
|--------|---------------------------------------|
| 프로젝트명  | AWS 클라우드 보안 설정 및 점검 체크리스트             |
| 목적     | AWS 환경의 기본 보안 설정을 직접 적용하고 점검 체크리스트 제작 |
| 사용 서비스 | AWS IAM, Amazon S3                    |
| 실습 환경  | AWS 프리 티어, 서울 리전(ap-northeast-2)      |
| 기간     | 2026년 6월                              |
| 작성자    | 이형석 (컴퓨터정보학부)                         |

## 2. AWS 클라우드 보안 핵심 개념

### 2.1 책임 공유 모델

AWS는 책임 공유 모델(Shared Responsibility Model)을 따른다. AWS는 클라우드 인프라 자체의 보안을 책임지고, 사용자는 클라우드 내부의 데이터와 접근 권한 설정에 대한 보안을 책임진다. 따라서 IAM 권한 관리와 데이터 접근 제어는 사용자가 반드시 직접 설정해야 하는 핵심 영역이다.

### 2.2 최소 권한 원칙

최소 권한 원칙(Principle of Least Privilege)은 사용자나 서비스에 업무 수행에 필요한 최소한의 권한만 부여하는 보안 원칙이다. 과도한 권한 부여는 계정 탈취 시 피해 범위를 키우므로, 권한을 세분화하여 관리하는 것이 중요하다.

## 3. 보안 설정 실습

### 3.1 루트 계정 MFA(다중 인증) 설정

루트 계정은 AWS 계정의 모든 권한을 가진 최상위 계정으로, 탈취 시 피해가 가장 크다. 이를 보호하기 위해 다중 인증(MFA)을 설정하였다. MFA는 비밀번호에 더해 인증 앱에서 생성되는 일회용 코드를 추가로 요구하여, 비밀번호가 유출되어도 계정을 보호한다.

| 항목    | 내용                                 |
|-------|------------------------------------|
| 설정 대상 | 루트 사용자(Root User)                  |
| 인증 방식 | 가상 MFA 디바이스 (Google Authenticator) |
| 효과    | 비밀번호 + 일회용 코드 2단계 인증으로 계정 보호 강화    |
| 결과    | MFA 디바이스 할당 완료                     |

**MFA 디바이스 할당됨**  
You can register up to 8 MFA devices of any combination of the currently supported MFA types with your AWS account root and IAM user. With multiple MFA devices, you only need one MFA device to sign in to the AWS console or create a session through the AWS CLI with that user.

**내 보안 자격 증명** [루트 사용자](#) [정보](#)

루트 사용자는 이 계정의 모든 AWS 리소스에 액세스할 수 있으며 다음 [모범 사례](#) [문\(들\)](#) 수행하는 것이 좋습니다. AWS 자격 증명의 유형과 사용 방식에 대해 자세히 알아보려면 [AWS 보안 자격 증명](#) [문\(들\)](#) 참조하세요.

**계정 세부 정보**

|                                                                 |                                                                                                                                        |
|-----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <b>계정 이름</b><br>leehs03<br><br><b>AWS 계정 ID</b><br>956314528701 | <b>이메일 주소</b><br>dligudtjr123456@naver.com<br><br><b>정규 사용자 ID</b><br>22fb6bb2bb6d3511a1decb8d16cd0e5fe325b7ed1d86fb0e2eb72ac6fa19e500 |
|-----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|

**멀티 팩터 인증(MFA) (1)**

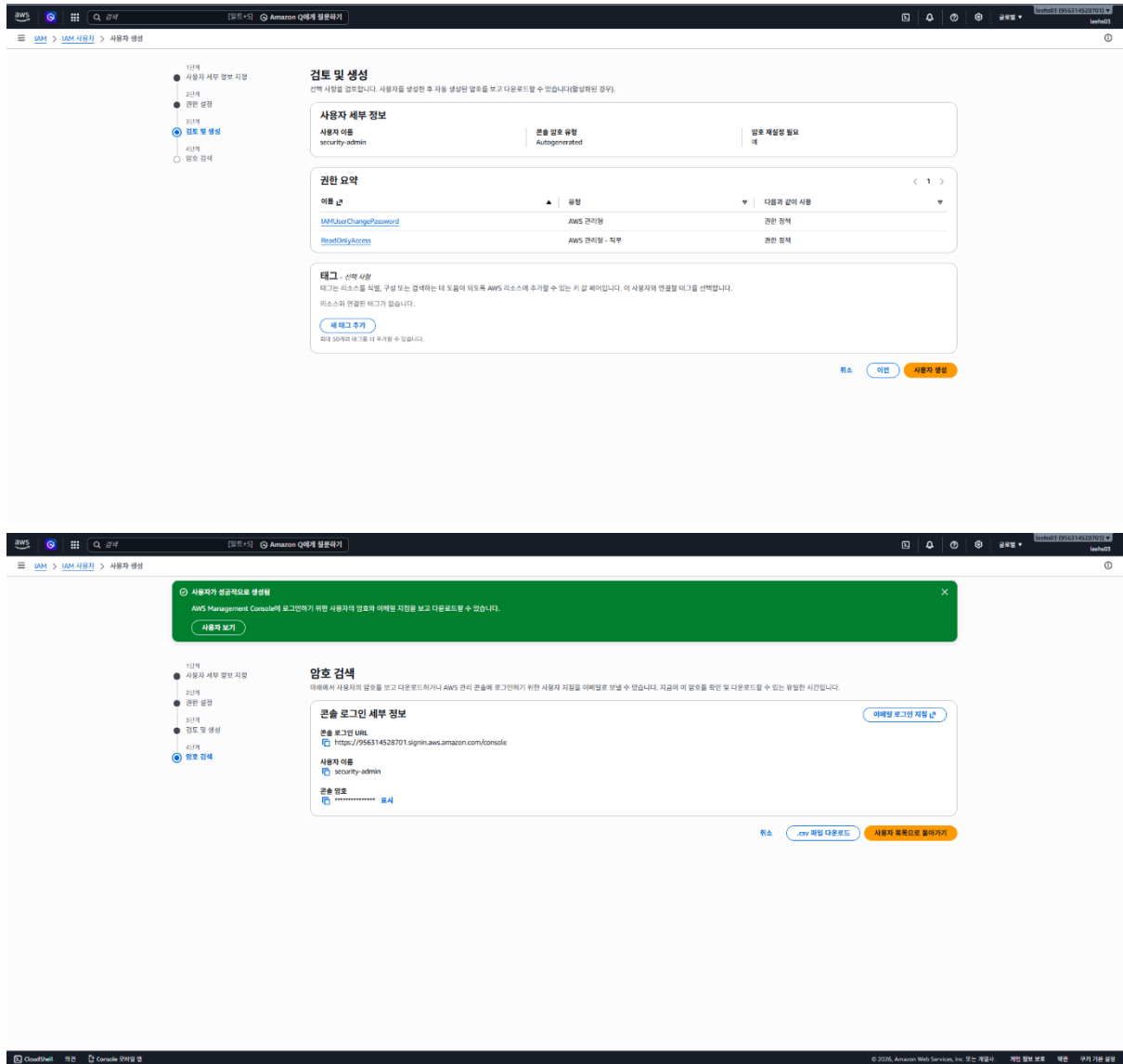
MFA를 사용하여 AWS 환경의 보안을 강화합니다. MFA로 로그인하려면 MFA 디바이스의 인증 코드가 필요합니다. 각 사용자는 MFA 디바이스를 최대 8개까지 할당할 수 있습니다. [자세히 알아보기](#)

| 유형                       | 식별자                                | 인증       | 생성 날짜           |
|--------------------------|------------------------------------|----------|-----------------|
| <input type="radio"/> 가상 | arn:awsiam:956314528701:mfa/my-mfa | 해당 사항 없음 | Wed Jun 03 2026 |

## 3.2 IAM 사용자 생성 및 최소 권한 부여

루트 계정을 일상적으로 사용하는 것은 보안상 위험하므로, 별도의 IAM 사용자를 생성하고 최소 권한을 부여하였다. 생성한 사용자에게는 조회 권한만 가진 `ReadOnlyAccess` 정책을 연결하여, 자원의 수정이나 삭제는 불가능하도록 제한하였다.

| 항목    | 내용                                  |
|-------|-------------------------------------|
| 사용자명  | security-admin                      |
| 콘솔 접근 | 허용 (자동 생성 암호, 최초 로그인 시 변경 필수)       |
| 연결 정책 | ReadOnlyAccess (조회 전용)              |
| 보조 정책 | IAMUserChangePassword (본인 암호 변경 허용) |
| 적용 원칙 | 최소 권한 원칙                            |



### 3.3 S3 버킷 퍼블릭 액세스 차단

Amazon S3는 클라우드 파일 저장 서비스로, 버킷이 실수로 외부에 공개되어 데이터가 유출되는 사고가 빈번하게 발생한다. 이를 방지하기 위해 버킷 생성 시 모든 퍼블릭 액세스 차단을 활성화하였고, 생성 후 권한 탭에서 차단 상태를 직접 확인하여 검증하였다.

| 차단 항목     | 설명                        |
|-----------|---------------------------|
| 새 ACL 차단  | 새로 추가되는 퍼블릭 액세스 ACL 생성 금지 |
| 임의 ACL 차단 | 기존 퍼블릭 ACL 무시             |
| 새 정책 차단   | 퍼블릭 액세스를 허용하는 새 버킷 정책 차단  |
| 임의 정책 차단  | 퍼블릭 및 교차 계정 액세스 정책 무시     |

## 버킷명: leehs03-security-test-2026

aws

검색

[알트+5]

Amazon Q에게 질문하기

아시아 태평양 (서울)

leehs03 (956314528701)

leehs03

Amazon S3 > 버킷 > 버킷 만들기

나쁜 AWS 계정에서 이 버킷에 작성한 객체의 소유권 및 액세스 제어 목록(ACL)의 사본을 제어합니다. 객체 소유권은 객체에 대한 액세스를 지정할 수 있는 사본을 결정합니다.

객체 소유권

ACL 비활성화됨(권장)

이 버킷의 모든 객체는 이 계정이 소유합니다. 이 버킷과 그 객체에 대한 액세스는 정책을 통해서만 지정됩니다.

ACL 활성화됨

이 버킷의 객체는 다른 AWS 계정에서 소유할 수 있습니다. 이 버킷 및 객체에 대한 액세스는 ACL을 사용하여 지정할 수 있습니다.

객체 소유권

버킷 소유자 적용

### 이 버킷의 퍼블릭 액세스 차단 설정

퍼블릭 액세스는 ACL(엑세스 제어 목록), 버킷 정책, 액세스 지정 정책 또는 모두를 통해 버킷 및 객체에 부여됩니다. 이 버킷 및 해당 객체에 대한 퍼블릭 액세스가 차단되었는지 확인하려면 모든 퍼블릭 액세스 차단을 활성화합니다. 이 설정은 이 버킷 및 해당 액세스 지정에만 적용됩니다. AWS에서는 모든 퍼블릭 액세스 차단을 활성화하도록 권장하지만, 이 설정을 적용하기 전에 퍼블릭 액세스가 없어도 애플리케이션이 올바르게 작동하는지 확인합니다. 이 버킷 또는 내부 객체에 대한 어느 정도 수준의 퍼블릭 액세스가 필요한 경우 특정 스토리지 사용 사례에 맞게 아래 개별 설정을 사용하지 지정할 수 있습니다. [자세히 알아보기](#)

- ☒ 모든 퍼블릭 액세스 차단
- 이 설정을 활성화하면 아래 4개의 설정을 모두 활성화한 것과 같습니다. 다음 설정 각각은 서로 독립적입니다.
- ☒ 새 ACL(엑세스 제어 목록)을 통해 부여된 버킷 및 객체에 대한 퍼블릭 액세스 차단

S3은 새롭거나 기존 버킷 또는 객체에 적용되는 퍼블릭 액세스 권한을 차단하며, 기존 버킷 및 객체에 대한 새 퍼블릭 액세스 ACL 생성을 금지합니다. 이 설정은 ACL을 사용하여 S3 리소스에 대한 퍼블릭 액세스를 허용하는 기존 권한을 변경하지 않습니다.

☒ 임의의 ACL(엑세스 제어 목록)을 통해 부여된 버킷 및 객체에 대한 퍼블릭 액세스 차단

S3은 버킷 및 객체에 대한 퍼블릭 액세스를 부여하는 모든 ACL을 무시합니다.

☒ 새 퍼블릭 버킷 또는 액세스 지정 정책을 통해 부여된 버킷 및 객체에 대한 퍼블릭 액세스 차단

S3은 버킷 및 객체에 대한 퍼블릭 액세스를 부여하는 새 버킷 및 액세스 지정 정책을 차단합니다. 이 설정은 S3 리소스에 대한 퍼블릭 액세스를 허용하는 기존 정책을 변경하지 않습니다.

☒ 임의의 퍼블릭 버킷 또는 액세스 지정 정책을 통해 부여된 버킷 및 객체에 대한 퍼블릭 및 교차 계정 액세스 차단

S3은 버킷 및 객체에 대한 퍼블릭 액세스를 부여하는 정책을 사용하는 버킷 또는 액세스 지정에 대한 퍼블릭 및 교차 계정 액세스를 무시합니다.

aws

검색

[알트+5]

Amazon Q에게 질문하기

아시아 태평양 (서울)

leehs03 (956314528701)

leehs03

Amazon S3 > 버킷 > leehs03-security-test-2026

버킷 'leehs03-security-test-2026'(가) 생성됨

leehs03-security-test-2026 정보

객체

메타데이터

속성

권한

지표

관리

파일 시스템 - 신규

엑세스 지정

객체 (0)

🔄

S3 URI 복사

🔗

URL 복사

📄

다운로드

🔗

열기

🗑️

삭제

⌵

작업

🔗

폴더 만들기

🚫

업로드

객체는 Amazon S3에 저장되어 있는 기본 엔티티입니다. [Amazon S3 인벤토리](#)를 사용하여 버킷에 있는 모든 객체의 목록을 얻을 수 있습니다. 다른 사용자가 객체에 액세스할 수 있게 하려면 명시적으로 권한을 부여해야 합니다. [자세히 알아보기](#)

🔍

접두사로 객체 찾기

<

1

>

⚙️

이름

▲

유형

▼

마지막 수정

▼

크기

▼

스토리지 클래스

▼

객체 없음  
이 버킷에 객체가 없습니다.  

🚫 업로드

CloudShell 의견 Console 모비일 앱

© 2026, Amazon Web Services, Inc. 또는 계열사. 개인 정보 보호 약관 쿠키 기본 설정

aws

검색

[알트+5]

Amazon Q에게 질문하기

아시아 태평양 (서울)

leehs03 (956314528701)

leehs03

Amazon S3 > 버킷 > leehs03-security-test-2026

leehs03-security-test-2026 정보

객체

메타데이터

속성

권한

지표

관리

파일 시스템 - 신규

엑세스 지정

권한 개요

엑세스 찾기

엑세스 조사 결과는 IAM 외부 액세스 분석기에서 제공됩니다. [IAM 분석기 조사 결과가 작동하는 방식](#)에 대해 자세히 알아보세요.

[ap-northeast-2에 대한 분석기 보기](#)

퍼블릭 액세스 차단(버킷 설정)

편집

퍼블릭 액세스는 ACL(엑세스 제어 목록), 버킷 정책, 액세스 지정 정책 또는 모두를 통해 버킷 및 객체에 부여됩니다. 모든 S3 버킷 및 객체에 대한 퍼블릭 액세스가 차단되었는지 확인하려면 [모든 퍼블릭 액세스 차단을 활성화합니다. 이 설정은 이 버킷 및 해당 액세스 지정에만 적용됩니다. AWS에서는 [모든 퍼블릭 액세스 차단을 활성화하도록 권장하지만, 이 설정을 적용하기 전에 퍼블릭 액세스가 없어도 애플리케이션이 올바르게 작동하는지 확인합니다. 버킷 또는 내부 객체에 대한 어느 정도 수준의 퍼블릭 액세스가 필요한 경우 특정 스토리지 사용 사례에 맞게 아래 개별 설정을 사용하지 지정할 수 있습니다. [자세히 알아보기](#)

모든 퍼블릭 액세스 차단

🟢

활성화

▶ 이 버킷의 개별 퍼블릭 액세스 차단 설정

버킷 정책

편집

삭제

JSON으로 작성된 버킷 정책은 버킷에 저장된 객체에 대한 액세스 권한을 제공합니다. 버킷 정책은 다른 계정이 소유한 객체에는 적용되지 않습니다. [자세히 알아보기](#)

CloudShell 의견 Console 모비일 앱

© 2026, Amazon Web Services, Inc. 또는 계열사. 개인 정보 보호 약관 쿠키 기본 설정

## 4. AWS 클라우드 보안 점검 체크리스트

본 실습을 바탕으로 AWS 환경에서 기본적으로 점검해야 할 보안 항목을 체크리스트로 정리하였다.

### 4.1 계정 및 인증 보안

| No | 점검 항목             | 기준 | 결과 |
|----|-------------------|----|----|
| 1  | 루트 계정 MFA 활성화     | 필수 | 완료 |
| 2  | 루트 계정 액세스 키 미사용   | 필수 | 완료 |
| 3  | IAM 사용자 별도 생성     | 필수 | 완료 |
| 4  | 강력한 암호 정책 적용      | 권장 | 완료 |
| 5  | 최초 로그인 시 암호 변경 강제 | 권장 | 완료 |

### 4.2 권한 관리

| No | 점검 항목           | 기준 | 결과 |
|----|-----------------|----|----|
| 6  | 최소 권한 원칙 적용     | 필수 | 완료 |
| 7  | 불필요한 관리자 권한 미부여 | 필수 | 완료 |
| 8  | 직무별 권한 분리       | 권장 | 완료 |

### 4.3 데이터 보안

| No | 점검 항목                | 기준 | 결과 |
|----|----------------------|----|----|
| 9  | S3 버킷 퍼블릭 액세스 차단     | 필수 | 완료 |
| 10 | 버킷 생성 후 차단 상태 검증     | 필수 | 완료 |
| 11 | ACL 비활성화 (버킷 소유자 적용) | 권장 | 완료 |

## 5. 결론 및 느낀점

본 실습을 통해 AWS 클라우드 환경에서 가장 기본이 되는 보안 설정인 MFA 다중 인증, IAM

최소 권한 관리, S3 퍼블릭 액세스 차단을 직접 적용하고 검증하는 경험을 쌓았다.

특히 클라우드 보안 사고의 상당수가 잘못된 권한 설정과 공개된 스토리지에서 발생한다는 점을 이해하고, 이를 예방하는 설정을 직접 실습함으로써 클라우드 보안의 실무적 중요성을 체감할 수 있었다.

SGA솔루션즈 TTS사업본부에서 클라우드 보안 솔루션을 다룰 때, 이번 실습에서 익힌 AWS 기본 보안 설정과 점검 체크리스트 작성 능력이 정기 점검 및 보안 운영 업무에 직접적으로 활용될 수 있을 것으로 기대한다.

## 6. 참고 자료

---

- AWS IAM 모범 사례: <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>
- Amazon S3 보안 모범 사례:  
<https://docs.aws.amazon.com/AmazonS3/latest/userguide/security-best-practices.html>